

Data Protection Impact Assessments (DPIAs)

Introduction

This document pulls in incorporates definitions and guidance from the Information Commissioner's Office (<https://ico.org.uk/>) Data Protection Commission of Ireland (<https://www.dataprotection.ie/>), the European Data Protection Board and the French Commission Nationale de l'Informatique et des Libertés (<https://www.cnil.fr/>) in addition to the risk-based approach that Data Protection Education takes in all our project and processing assessments.

That risk-based approach is based on guidance issued by the Article 29 Data Protection Working Party¹ and the Centre for International Policy and Leadership² and is based on our belief that whilst a DPIA might not always be required, there is an element of risk in every processing activity and that using risk as a guide, we can focus on the correct priorities in relation to organisational and technical operations as well as documented accountability.

This approach allows us to ensure that we can deliver the most effective service with the greatest benefits to the individual organisation we work with by prioritising risk in all data processing activities, assessing the risk and working top-down on implementing mitigation. It provides flexibility for each organisation and accountability for even the smallest data processing organisation.

¹ Statement on the role of a risk-based approach in data protection legal frameworks, Adopted on 30 May 2014,
https://ec.europa.eu/justice/article-29/documentation/opinion-recommendation/files/2014/wp218_en.pdf)

² Risk, High Risk, Risk Assessments and Data Protection Impact Assessments under the GDPR. CIPL GDPR Interpretation and Implementation Project, 21 December 2016,
https://www.informationpolicycentre.com/uploads/5/7/1/0/57104281/cipl_gdpr_project_risk_white_paper_21_december_2016.pdf

What is a Data Protection Impact Assessment?

When your organisation collects, stores, or uses personal data, the individuals whose data you are processing are exposed to risks. These risks range from personal data being stolen or inadvertently released and used by criminals to impersonate the individual, to worry being caused to individuals that their data will be used by your organisation for unknown purposes. A Data Protection Impact Assessment (DPIA) describes a process designed to identify risks arising out of the processing of personal data and to minimise these risks as far and as early as possible. DPIAs are important tools for negating risk, and for demonstrating compliance with the GDPR.

DPIAs should be conducted for a defined project, rather than for an organisation's operations as a whole. A particular function of your organisation, or a programme of changes to your organisation's operations as a whole, may be viewed as a project.

What are the benefits of conducting a DPIA?

Conducting a DPIA will improve awareness in your organisation of the data protection risks associated with a project. This will help to improve the design of your project and enhance your communication about data privacy risks with relevant stakeholders. Some of the benefits of conducting a DPIA are as follows:

- Ensuring and demonstrating that your organisation complies with the GDPR and avoids sanctions.
- Inspiring confidence in the public by improving communications about data protection issues.
- Ensuring your users are not at risk of their data protection rights being violated.
- Enabling your organisation to incorporate "data protection by design" into new projects.
- Reducing operation costs by optimising information flows within a project and eliminating unnecessary data collection and processing.
- Reducing data protection related risks to your organisation.
- Reducing the cost and disruption of data protection safeguards by integrating them into project design at an early stage.

Data protection by design means embedding data privacy features and data privacy enhancing technologies directly into the design of projects at an early stage. This will help to ensure better and more cost-effective protection for individual data privacy.

Data protection by default means that service settings must be automatically data protection friendly.

While long recommended as good practice, both of these principles are enshrined in law under the GDPR (Article 25).

How do I know if a DPIA should be conducted?

Under the GDPR, a DPIA is mandatory where data processing “is likely to result in a high risk to the rights and freedoms of natural persons”. This is particularly relevant when a new data processing technology is being introduced. In cases where it is not clear whether a DPIA is strictly mandatory, carrying out a DPIA is still good practice and a useful tool to help data controllers comply with data protection law.

The GDPR provides some non-exhaustive examples of when data processing is “likely to result in high risks”:

- “A systematic and extensive evaluation of personal aspects relating to natural persons which is based on automated processing, including profiling, and on which decisions are based that produce legal effects concerning the natural person or similarly significantly affect the natural person.”
- “Processing on a large scale of special categories of data referred to in Article 9(1), or of personal data relating to criminal convictions and offences referred to in Article 10.”
- “A systematic monitoring of a publicly accessible area on a large scale.”

The Article 29 Working Party, consisting of the representatives from each data protection authority in the EU, has adopted guidelines on DPIAs and whether processing is likely to result in a high risk for the purposes of the GDPR. [The guidelines are available here](#). In assessing whether processing is likely to result in a high risk the Article 29 Working Party has set forth the following criteria to consider:

- Evaluation or scoring, including profiling and predicting, especially “from aspects concerning the data subject’s performance at work, economic situation, health, personal preferences or interests, reliability or behaviour, location or movements” (recitals 71 and 91). Examples of this could include a bank that screens its customers against a credit reference database, or a biotechnology company offering genetic tests directly to consumers in order to assess and predict the disease/health risks, or a company building behavioural or marketing profiles based on usage or navigation on its website.
- Automated decision making with legal or similar significant effect: processing that aims at taking decisions on data subjects producing “legal effects concerning the natural person” or which “similarly significantly affects the natural person” (Article 35 (3)(a)). For example, the processing may lead to the exclusion or discrimination against individuals. Processing with little or no effect on individuals does not match this specific criterion.
- Systematic monitoring: processing used to observe, monitor or control data subjects, including data collected through “a systematic monitoring of a publicly accessible area” (Article 35 (3)(c)). This type of monitoring is a criterion because the personal data may be collected in circumstances where data subjects may not be aware of who is collecting their data and how they will be used. Additionally, it may be

impossible for individuals to avoid being subject to such processing in frequent public (or publicly accessible) space(s).

- Sensitive data: this includes special categories of data as defined in Article 9 (for example information about individuals' political opinions), as well as personal data relating to criminal convictions or offenses. An example would be a general hospital keeping patients' medical records or a private investigator keeping offenders' details. This criterion also includes data which may more generally be considered as increasing the possible risk to the rights and freedoms of individuals, such as electronic communication data, location data, financial data (that might be used for payment fraud). In this regard, whether the data has already been made publicly available may be considered as a factor in the assessment if the data was expected to be further used for certain purposes. This criterion may also include information processed by a natural person in the course of purely personal or household activity (such as cloud computing services for personal document management, email services, diaries, e-readers equipped with note taking features, and various life-logging applications that may contain very personal information), whose disclosure or processing for any other purpose than household activities can be considered as very intrusive.
- Data processed on a large scale: the GDPR does not define what constitutes large-scale, though recital 91 provides some guidance. In any event, the WP29 recommends that the following factors, in particular, be considered when determining whether the processing is carried out on a large scale:
 - The number of data subjects concerned, either as a specific number or as a proportion of the relevant population.
 - The volume of data and/or the range of different data items being processed.
 - The duration, or permanence, of the data processing activity.
 - The geographical extent of the processing activity.
 - Datasets that have been matched or combined, for example originating from two or more data processing operations performed for different purposes and/or by different data controllers in a way that would exceed the reasonable expectations of the data subject.
- Data concerning vulnerable data subjects (recital 75): the processing of this type of data can require a DPIA because of the increased power imbalance between the data subject and the data controller, meaning the individual may be unable to consent to, or oppose, the processing of his or her data. For example, employees would often meet serious difficulties to oppose the processing performed by their employer, when it is linked to human resources management. Similarly, children can't be considered as not able to knowingly and thoughtfully oppose or consent to the processing of their data. This also concerns more vulnerable segments of the population requiring special protection, such as, for example, the mentally ill, asylum seekers, or the elderly, a patient, or in any case where an imbalance in the relationship between the position of the data subject and the controller can be identified.
- Innovative use or applying technological or organisational solutions, like combining use of fingerprint and face recognition for improved physical access control, etc. The

GDPR makes it clear (Article 35(1) and recitals 89 and 91) that use of a new technology can trigger the need to carry out a DPIA. This is because the use of a new technology can involve novel forms of data collection and usage, possibly with a high risk to individuals' rights and freedoms. Indeed, the personal and social consequences of the deployment of a new technology may be unknown. A DPIA will help the data controller to understand and to treat such risks. For example, certain "Internet of Things" applications could have a significant impact on individuals' daily lives and privacy; and therefore require a DPIA.

- Data transfer across borders outside the European Union (recital 116), taking into consideration, amongst others, the envisaged country or countries of destination, the possibility of further transfers, or the likelihood of transfers based on derogations for specific situations set forth by the GDPR.
- When the processing in itself "prevents data subjects from exercising a right or using a service or a contract" (Article 22 and recital 91). This includes processings performed in a public area that people passing by cannot avoid, or processings that aim at allowing, modifying or reusing data subjects' access to a service or entry into a contract. An example of this is where a bank screens its customers against a credit reference database in order to decide whether to offer them a loan.

The Working Party considers that the more criteria are met by the processing, the more likely it is to present a high risk to the rights and freedoms of data subjects, and therefore to require a DPIA. As a rule of thumb, a processing operation meeting less than two criteria may not require a DPIA due to the lower level of risk, and processing operations which meet at least two of these criteria will require a DPIA. If the controller believes that a processing operation which meets at least two of these criteria is not likely to be high risk, the controller should thoroughly document the reasons for not carrying out a DPIA.

When is a DPIA not required?

A DPIA is generally not required in the following cases:

- Where the processing is not "likely to result in a high risk to the rights and freedoms of natural persons" (article 35(1)).
- When the nature, scope, context and purposes of the processing are very similar to the processing for which DPIAs have been carried out. In such cases, results of a DPIA for similar processing can be used (Article 35(1)).
- Where a processing operation has a legal basis in EU or Member State law and has stated that an initial DPIA does not have to be carried out, where the law regulates the specific processing operation and where a DPIA, according to the standards of the GDPR, has already been carried out as part of the establishment of that legal basis (Article 35(10)).
- Where the processing is included on the optional list (established by the supervisory authority) of processing operations for which no DPIA is required (Article 35(5)). Such a list may contain processing activities that comply with the conditions specified by this authority, in particular through guidelines, specific decisions or authorisations,

compliance rules, etc. In such cases, and subject to reassessment by the competent supervisory authority, a DPIA is not required, but only if the processing falls strictly within the scope of the relevant procedure mentioned in the list and continues to comply fully with the relevant requirements.

Is a DPIA mandatory for existing processing operations, existing before the GDPR became effective on the 25 May 2018?

The GDPR became effective from the 25 May 2018, and DPIAs are legally mandatory only for processing operations that are initiated after this date. Nevertheless, the Article 29 Working Party strongly recommended carrying out DPIAs for all high risk operations prior to this date. Indeed a DPIA can be a powerful tool in ensuring that any operations will not leave you at risk of non-compliance after 25 May 2018, and save your organisation from operational disruption by allowing you to future proof new projects against the GDPR at an early stage.

Additionally, new DPIAs or reviews of DPIAs for existing processing that commenced before the 25 May 2018 may be required in the following circumstances:

- Where a significant change to the processing operation has taken place after the GDPR takes effect. For example, when a new technology comes into use, or when data is being used for a different purpose. In these cases the processing is effectively a new operation and could require a DPIA.
- When there is a change of the risk presented by the processing operation. The risks and level of risk can change as a result of a change to one of the components of the processing operation (data, supporting assets, risk sources, etc.), or because the context of the processing evolves (purpose, functionalities, etc.). Data processing systems can evolve over time, and new threats and vulnerabilities can arise.
- The organisational or societal context for the processing activity has changed, for example because the effects of certain automated decisions have become more significant, new categories of natural persons become vulnerable to discrimination or the data is intended to be transferred to data recipients located in a country which has left the EU.

As a matter of good practice, the Article 29 Working Party recommends that all DPIAs should be reassessed after 3 years, or sooner if circumstances have changed quickly.

When in a project lifecycle should a DPIA be conducted?

The DPIA should be carried out “prior to the processing” (GDPR Articles 35(1) and 35(10), recitals 90 and 93). **It is generally good practice to carry out a DPIA as early as practical in the design of the processing operation.** It may not be possible to conduct a DPIA at the very inception of the project, as project goals and some understanding of how the project will operate must be identified before it will be possible to assess the data protection risks involved.

For some projects the DPIA may need to be a continuous process, and be updated as the project moves forward. The fact that a DPIA may need to be updated once processing has actually started is not a valid reason for postponing or not carrying out a DPIA.

Who should be involved in conducting the DPIA?

The data controller is responsible for ensuring the DPIA is carried out. It may be delegated to someone else, inside or outside the organisation, but the data controller is ultimately accountable.

The DPIA should be driven by people with appropriate expertise and knowledge of the project in question, normally the project team. If your organisation does not possess sufficient expertise and experience internally, or if a particular project is likely to hold a very high level of risk or affect a very large number of people, you may consider bringing in external specialists to consult on or to carry out the DPIA.

A wide internal consultation process can benefit the DPIA, as some data protection risks will only be apparent to individuals working on specific aspects of the project. It will also allow you to gain feedback from those whose work will be affected by the project after implementation, such as engineers, designers and developers, who will have a practical knowledge of the operations. Involving your organisation's public relations team will allow for effective communication of the DPIA's outcomes to external stakeholders.

Under the GDPR (Article 35), it is necessary for any data controller with a designated Data Protection Officer (DPO) to seek the advice of the DPO. This advice and the decisions taken should be documented as a part of the DPIA process. If a data processor is involved in the processing, the data processor should assist with the DPIA and provide any necessary information.

The Data Protection Officer (DPO) is a designated person appointed by an organisation to advise on data protection practices within the organisation. The DPO can be a staff member or an external service provider. Under the GDPR, appointment of a DPO is mandatory in the following circumstances:

- For public bodies carrying out data processing, except for courts acting in their judicial capacity;
- If the core activities of the organisation consist of data processing which, by virtue of their scope and/or purposes, require regular and systematic monitoring of data subjects on a large scale; or
- The core activities of the organisation consist of processing on a large scale of special categories of data as outlined in Article 9 or personal data relating to criminal convictions as outlined in Article 10 of the GDPR.

The data controller is bound to “seek the views of data subjects or their representatives” (Article 35(9)), “where appropriate” in carrying out the DPIA. In some cases, the data subjects may be people within the organisation. Seeking the views of data subjects will allow the data controller to understand the concerns of those who may be affected, and to improve transparency by making individuals aware of how their information will be used.

The views of data subjects can be sought through a variety of means, depending on the context. Staff could be consulted through a trade union; customers could be consulted by means of a survey. If the data controller’s final decision differs from the views of data subjects, the reasons should be recorded as a part of the DPIA. If the data controller does not feel it appropriate to seek the views of data subjects, the justification for this should be documented.

What steps are involved in carrying out a DPIA?

The GDPR sets out the minimum features of a DPIA (Article 35(7), and recitals 84 and 90):

- “a description of the envisaged processing operations and the purposes of the processing”
- “an assessment of the necessity and proportionality of the processing”
- “an assessment of the risks to the rights and freedoms of data subjects”
- “the measures envisaged to:
- “address the risks”;
- “demonstrate compliance with this Regulation”.

The GDPR presents a broad, generic framework for designing and carrying out a DPIA. This allows for scalability, so even the smallest data controllers can design and implement a DPIA; as well as for flexibility, so the data controller can determine the precise structure and form of the DPIA, allowing it to fit with existing working practices.

For details on conducting DPIAs using the DPE Knowledge Bank Record of Processing Tool, see the document: DPE DPIA Methodology.